

Chapitre 9

Sécurité

La sécurité doit être prise en considération lors de l'installation et l'utilisation d'un ordinateur.

Les attaques touchent généralement les trois composantes suivantes :

- La couche d'application
- Le système d'exploitation
- La couche réseau

On distingue différentes attaques au sein d'un réseau dû à la faiblesse des composants :

- Faiblesses d'authentification.
- Mauvaises configurations.
- Faiblesses d'implémentation ou de bogues ;
- Faiblesses liées aux protocoles.

La gestion des utilisateurs est fondamentale dans la sécurité d'un système informatique. De mauvaises privilèges ou un mauvais mot de passe peuvent compromettre la sécurité d'un ordinateur.

Mots de passe

Pour éviter les attaques qui utilisent un dictionnaire, le mot de passe doit être fort. Il doit :

- comporter des lettres minuscules et majuscules, des nombres et d'autres caractères ;
- comporter au moins 12 caractères ;

Il ne doit pas comporter :

- Le nom ou le prénom de l'utilisateur ;
- La date de naissance de l'utilisateur ;
- Un mot du dictionnaire.

Générateur

```
$ sudo apt install pwgen
$ pwgen -s 16 1
A1IcFptHqg7xTufY
$ pwgen -y -s 16 1
=Y^J}hy^=G$1;SB{
```

Permissions Avancées : SUID, SGID et Sticky Bit

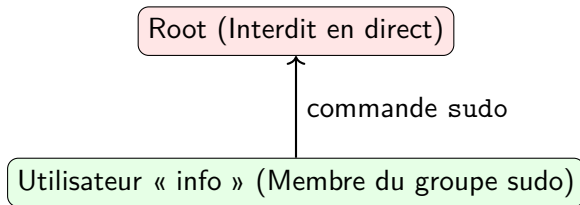
- **SUID (Set User ID)** : Exécute le fichier avec les droits du propriétaire (ex : passwd).
Danger : vecteur d'escalade de privilèges.
- **SGID (Set Group ID)** : Exécute avec les droits du groupe ou force l'héritage du groupe dans un dossier.
- **Sticky Bit** : Seul le propriétaire peut supprimer son fichier dans un dossier partagé (ex : /tmp).

Commande de recherche de failles

```
find / -perm -4000 -type f 2>/dev/null
```

(Cherche tous les fichiers SUID root sur le système)

Élévation de privilèges : Le fichier sudoers



- Ne jamais se loguer en root. Utiliser sudo.
- **Règle d'or** : Principe du moindre privilège.

Le principe du moindre privilège

Un utilisateur ne doit posséder que les droits strictement nécessaires à l'accomplissement de sa tâche.

L'utilisation de sudo (Superuser do) permet de :

- Tracer les actions privilégiées (logs dans `/var/log/auth.log`).
- Déléguer des permissions granulaires.
- Éviter le partage du mot de passe root.

Configuration : /etc/sudoers

- Ne jamais éditer directement avec `nano` ou `vim`.
- Toujours utiliser la commande `visudo` qui vérifie la syntaxe avant de sauvegarder.

Exemple de règle sudoers

```
etudiant ALL=(ALL) /bin/systemctl restart apache2
```

Pour sécuriser un réseau, il faut :

- Segmenter le réseau en sous-réseaux ;
- Utiliser des filtres ;
- Utiliser un pare-feu.

Segmenter le réseau en sous-réseaux

Dans le but de séparer les machines sensibles des autres machines, on peut découper un réseau en plusieurs sous-réseaux, alors que l'ensemble continue à se comporter comme un seul réseau vis-à-vis de l'extérieur.

La première étape de la sécurisation réseau consiste à savoir quels ports sont ouverts en écoute.

- Commande `ss` :
`ss -tulpn`
- Commande `lsof` :
`sudo lsof -i -P -n | grep LISTEN`

Introduction au Pare-feu UFW

UFW (Uncomplicated Firewall) est une interface simplifiée pour configurer `iptables` ou `nftables` sous Ubuntu.

- Conçu pour être facile à utiliser tout en restant puissant.
- Activé par défaut en mode « Refuser tout le trafic entrant, Autoriser tout le trafic sortant ».

Commandes UFW essentielles

```
# Activer le pare-feu
```

```
sudo ufw enable
```

```
# Autoriser SSH
```

```
sudo ufw allow ssh
```

```
# Autoriser un réseau spécifique sur un port
```

```
sudo ufw allow from 192.168.1.0/24 to any port 3306
```

```
# Vérifier le statut
```

```
sudo ufw status numbered
```

Ubuntu remplace progressivement iptables par nftables.

- Plus performant et syntaxe unifiée.
- Gère les adresses IPv4 et IPv6 dans la même table.
- Permet des structures de données (sets/maps) très rapides pour les grandes listes d'IPs.

Sécurisation du service SSH (1/2)

Le service SSH est la porte d'entrée principale des serveurs. Fichier : `/etc/ssh/sshd_config`

- Port 2222 : Changer le port par défaut.
- PermitRootLogin no : Interdire la connexion directe en root.
- AllowUsers prof etudiant1 : Restreindre les utilisateurs autorisés.

Sécurisation du service SSH (2/2) : Clés asymétriques

Désactiver l'authentification par mot de passe au profit des clés cryptographiques (Ed25519 ou RSA).

- `PasswordAuthentication no`
- `PubkeyAuthentication yes`

Génération : `ssh-keygen -t ed25519`

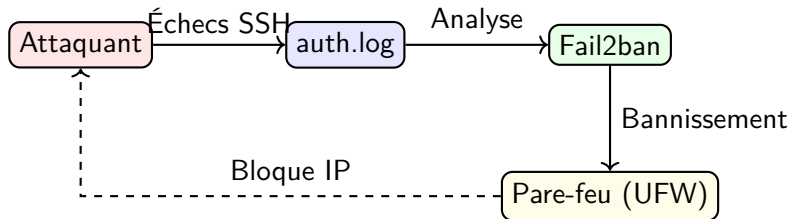
Copie : `ssh-copy-id utilisateur@serveur`

Protection contre le Brute-Force : Fail2ban

Fail2ban analyse les fichiers de logs en temps réel et bannit dynamiquement (via UFW/nftables) les adresses IP ayant des comportements suspects.

- Idéal pour protéger SSH, Nginx, ou même Proxmox.

Architecture de Fail2ban



Configuration de Fail2ban (Jails)

Créer un fichier local : /etc/fail2ban/jail.local

```
[sshd]
enabled = true
port    = 2222
logpath = %(sshd_log)s
backend = %(sshd_backend)s
maxretry = 3
bantime = 3600
```

La première règle de sécurité : **Un système à jour.**

- Commande : `apt update && apt upgrade -y`
- Automatisation critique pour les correctifs de sécurité via le paquet `unattended-upgrades`.

Permet l'installation automatique des mises à jour de sécurité de manière silencieuse.

- Configuration dans `/etc/apt/apt.conf.d/50unattended-upgrades`.
- Ne cible par défaut que le dépôt de sécurité d'Ubuntu.

Canonical Livepatch Service

Les mises à jour du noyau Linux nécessitent un redémarrage, provoquant un temps d'arrêt.

Livepatch

Permet d'appliquer des correctifs de sécurité critiques au noyau Linux en temps réel, **sans redémarrer** la machine.

Activation d'ubuntu pro : Ubuntu Pro est gratuit pour un usage personnel sur 5 machines

- Connectez-vous à votre tableau de bord sur <https://ubuntu.com/pro>
- Copiez votre Token affiché dans la section « Free Personal Token » du « dashboard » (<https://ubuntu.com/pro/dashboard>)
- Mettre à jour le système :

```
sudo apt update && sudo apt upgrade
```

- Attacher la machine :

```
sudo pro attach <VOTRE_TOKEN>
```

- Verrouillez votre écran quand vous vous éloignez (Ctrl+Alt+L).
- Mot de passe BIOS/UEFI pour interdire le démarrage sur un média externe.
- Désactivez les ports USB en écriture si nécessaire .
- Utilisez un câble de sécurité pour les postes fixes.

Sauvegardes et reprise après sinistre

- **Deja Dup** (GUI) : sauvegarde incrémentielle, chiffrée.
- **Timeshift** : snapshots système (comme la restauration système).
- **BorgBackup** : déduplication, chiffrement, compression.
- Règle 3-2-1 : 3 copies, 2 supports différents, 1 hors site.

Systèmes de Détection/Prévention d'Intrusions

Définition

Un système de Détection/Prévention d'Intrusions (**IDS** - Intrusion Detection System) est un outil de surveillance qui analyse l'activité d'un réseau ou d'un ordinateur pour repérer des comportements suspects ou des violations de politiques de sécurité.

Un IDS permet de :

- Surveiller
- Contrôler
- Détecter

Le système de détection d'intrusion est un composant critique d'une architecture de sécurité informatique.

Définition

L'audit informatique (en anglais Information Technology Audit ou IT Audit) a pour objectif d'identifier et d'évaluer les risques (opérationnels, financiers, de réputation notamment) associés aux activités informatiques d'une entreprise ou d'une administration.

Les tests d'intrusion

Définition

Un test d'intrusion (« penetration test » ou « pentest » en anglais) est une méthode d'évaluation de la sécurité d'un système ou d'un réseau informatique.

Article 607-3 du code pénal

le fait d'accéder, frauduleusement, dans tout ou partie d'un système de traitement automatisé des données est puni **d'un mois à trois mois d'emprisonnement** et de **2 000 à 10 000 dirhams** ou de l'une de ces deux peines seulement.

Nmap

C'est un scanner de ports. Il est conçu pour détecter les ports ouverts, identifier les services hébergés et obtenir des informations sur le système d'exploitation d'un ordinateur **distant**.

Exemple : détecter le système d'exploitation et les ports ouverts

```
sudo nmap -O 192.168.56.1
```

Audit du Noyau avec auditd

Permet de tracer l'exécution des appels système et la modification de fichiers sensibles avec une précision légale (Forensics).

```
# Tracer les modifications du fichier /etc/passwd
auditctl -w /etc/passwd -p wa -k passwd_changes

# Lire les rapports
ausearch -k passwd_changes
```

Scanners de Sécurité (1/2) : Lynis

Lynis est un outil d'audit de sécurité open-source. Il effectue des centaines de tests et propose un score de durcissement ainsi que des recommandations.

- Commande : `sudo lynis audit system`
- Extrêmement utile pour préparer une certification ou auditer une infrastructure cloud.

Un rootkit est un ensemble de logiciels malveillants conçus pour dissimuler sa présence et maintenir un accès privilégié.

- **chkrootkit** : Outil en ligne de commande pour vérifier les signes locaux d'une infection.
- **rkhunter** (Rootkit Hunter) : Version plus avancée qui compare les hash SHA-1 des binaires avec une base de données saine.

Check-list de durcissement (Hardening)

- ➊ Mises à jour automatisées (`unattended-upgrades`).
- ➋ Durcissement de SSH (clés uniquement, changement de port).
- ➌ Activation et configuration du pare-feu (`ufw`).
- ➍ Installation d'un bannissement d'IP (`fail2ban`).
- ➎ Vérification de l'absence de services non nécessaires.
- ➏ Mise en place d'une politique de sauvegarde robuste.

Audit et Traçabilité : Les Journaux (Logs)

Un administrateur doit surveiller les traces d'activité :

- `/var/log/auth.log` : Tentatives de connexion (SSH, sudo).
- `/var/log/syslog` : Événements généraux du système.
- **Commande clé** : `journalctl -u ssh -f` (Suivi en temps réel).

Important

Un attaquant cherchera toujours à effacer ses traces (`history -c`, suppression des fichiers logs). L'externalisation des logs vers un serveur distant est recommandée.

- La sécurité est un processus continu, pas un produit.
- Ubuntu offre d'excellentes bases, mais la configuration est indispensable.
- Appliquez le principe du moindre privilège.
- Restez informé des vulnérabilités.
- Pensez à la sécurité dès la conception de votre environnement.